Ghulam Ishaq Khan Institute of Engineering Sciences and Technology (GIKI)

Deliverable 1

for

Secure P2P Chat System

Version 1.0

by

Muhammad Bin Waseem	**2023403**
Muhammad Shaheer	**2023509**
Muhmmad Zaeem Nawaz	**2023550**

Instructor

Dr. Zubair

Bachelor of Science in Cyber Security (2023-2027)

Faculty of Computer Science and Engineering (FCSE)

1. Security Requirements

Core Requirements

These are the nonnegotiable requirements that must be fullfilled for our secure Communication system :

Confidentiality: End-to-End Encryption (E2EE) is mandatory. For that we will use asymmetric encryption e.g RSA for key exchange and symmetric encryption e.g AES for the message payload.

Integrity: Implement Message Authentication Codes (MACs) or digital signatures to ensure that messages are not tampered with in transit between peers.

Availability: the system must handle peer discovery using Distributed Hash Tables - DHT to ensure users can find each other consistently.

Authentication & Authorization: Peers must verify the identity of the person they are connecting to.

Accountability: Keep local, encrypted logs of session handshakes to audit connection attempts, ensuring no shadow peers are intercepting traffic.

General Requirements

Session Management: Since there is no central login, sessions must be managed through ephemeral keys. If a session is closed, the keys should be purged from memory.

Error/Exceptions Management: The system must fail gracefully. If a handshake fails or a malformed packet is received, the application should drop the connection rather than leaking system state or memory.

Operational Requirements

Deployment Environment: The software must be designed to handle various network conditions, specifically NAT Traversal to allow peers to connect behind home routers without compromising local network security.

Anti-piracy/Integrity of Executable: Ensure that the distributed client has a checksum or digital signature so peers can verify they are running the official, untampered version of your group's software

2. Comprehensive Risk Management Plan

Risk ID	Threat Category	Risk Description	Likelihood	Impact	Mitigation Status
RM-01	Supply Chain	Unprivileged access via vulnerable third-party dependencies.	High	Critical	Weekly cargo audit and dependency scanning.
RM-02	Spoofing	Compromise of user accounts through authentication attacks.	Medium	Critical	Ed25519 signing and multi-layered access control.
RM-03	Disclosure	Leakage of sensitive data (PII) from local storage/logs.	Medium	Critical	Data masking and AES-256 encryption at rest.
RM-04	Tampering	Input manipulation via malicious message payloads or URLs.	High	High	Comprehensive input validation and URL sanitization.
RM-05	DoS	Resource exhaustion or service denial through flooding.	High	High	Implement rate limiting and resource allocation.

3. **Threat Modeling**

This threat model is based on the STRIDE framework .

- **Spoofing :** Attackers may attempt to impersonate a peer by stealing private keys.

  Control: Enforce principle of least privilege for key access and secure transmission of public keys.

- **Information Disclosure :** Weak encryption of sensitive user credentials.

  Control: Implement advanced encryption standards with effective key management.

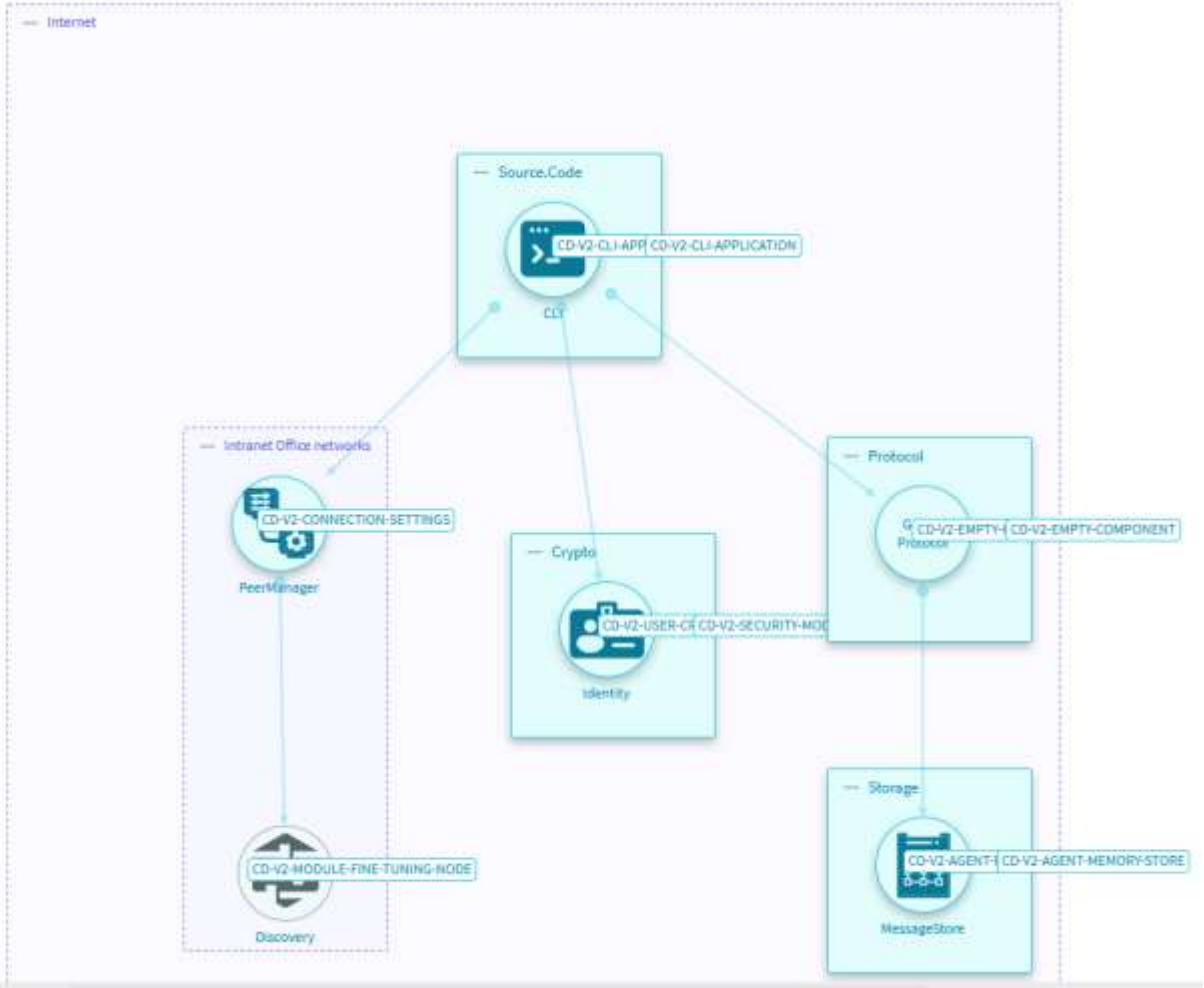
- **Denial of Service :** A malicious peer could flood the network to cause a broadcast storm.

  Control: Deploy redundancy and rate limiting across all network connections.
- **Tampering :** Memory manipulation through abnormal access patterns during message relay.

  Control: Monitor and audit memory operations; filter all external inputs.
- **Information Disclosure :** Inadequate data protection for stored chat history (PII).

  Control: Apply data masking, tokenization, and strong encryption for all data at rest.

Tampering : Poisoning stored data via RAG or memory injection.

Control: Enforce process isolation (sandboxing) and validate memory integrity.

4. Architecture Diagram